

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE CODE: CSA51

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 40%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A CONSTRAINT-BASED PROBLEM SOLVING

Code of Conduct:

*I SAIRAM D 192424111 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student: SAIRAM D

Annexure A CONSTRAINT-BASED PROBLEM SOLVING

1. A financial institution must secure all web transactions using TLS, but legacy systems only support older SSL versions. Design a solution to ensure secure communication.

Constraints:

- A. Backward compatibility must be maintained for 20% legacy clients
- B. Sensitive data must not be transmitted using SSL
- C. System downtime must be minimal during migration
- D. Cost of implementation should be optimized

Scenario: A financial institution must secure all web transactions using TLS, but legacy systems only support older SSL versions. Design a solution to ensure secure communication.

Constraints: (A) Backward compatibility must be maintained for 20% legacy clients (B) Sensitive data must not be transmitted using SSL (C) System downtime must be minimal during migration (D) Cost of implementation should be optimized.

1. Problem Understanding

The institution faces a direct conflict between **security** and **compatibility**: TLS (specifically TLS 1.2/1.3) is mandatory for protecting financial transactions because legacy SSL (SSLv2/SSLv3) and early TLS versions are cryptographically broken (vulnerable to POODLE, BEAST, DROWN and padding-oracle style attacks) and are explicitly disallowed by PCI-DSS for handling cardholder/financial data. However, 20% of the client base runs legacy systems that cannot negotiate modern TLS. The core problem is therefore to design a **migration architecture** that enforces strong encryption for all sensitive data while still allowing the legacy segment to function, without large outages and without excessive capital expenditure. The problem is essentially one of **protocol-version governance with segmented risk exposure**, not a simple protocol swap.

2. Constraint Analysis & Prioritisation

Constraint	Description	Priority & Rationale
B	Sensitive/financial data must never travel over SSL.	Highest (non-negotiable). This is a regulatory / integrity constraint (PCIDSS, RBI-IT guidelines). Any violation exposes the institution to breach liability, so it overrides convenience or cost.
A	20% legacy clients must still be able to connect.	High (business continuity). Cannot be ignored, but it must be satisfied only for <u>non-sensitive</u> functions once B is guaranteed – i.e., A is subordinate to B.
C	Downtime during migration must be minimal.	Medium (operational). Affects customer trust and SLA commitments; managed through phased cut-over rather than a single 'big-bang' switch.
D	Implementation cost should be optimised.	Lower (economic). Addressed last, by choosing open-standard/open-source components once the security and continuity requirements are already satisfied.

Resulting priority order derived from the analysis: **B > A > C > D**. This ordering drives every design decision in Section 3: security is designed first, compatibility is layered around it, migration mechanics are chosen to protect uptime, and only then is the cheapest compliant technology selected.

3. Solution Development

Proposed architecture – "TLS-Enforced Gateway with Legacy Isolation":

- **Protocol-aware reverse proxy / load balancer** (e.g., NGINX, HAProxy or F5) is placed in front of all application servers and terminates TLS centrally, so application code does not need to change.
- **Strict channel separation:** All endpoints that carry sensitive data – login, funds transfer, account/card details, OTP – are configured to accept TLS 1.2/1.3 only, with weak ciphers (RC4, 3DES, export-grade suites) disabled. This directly satisfies constraint B: sensitive data physically cannot be negotiated over SSL.
- **Legacy channel for non-sensitive interaction only:** A separate, network-

segmented gateway is allowed to accept the older protocol strictly for read-only / public content (branch locator, FAQs, static rate sheets) for the 20% legacy clients, satisfying constraint A without breaching B.

- **Phased / parallel (blue-green) migration:** The new TLS-only cluster is deployed alongside the existing infrastructure and traffic is shifted gradually (DNS weighting or load-balancer routing), so there is no single cut-over window and constraint C (minimal downtime) is met.
- **Mandatory client upgrade programme:** Legacy clients are given a fixed grace period (e.g., 2–6 months) with in-app/portal notices, after which the legacy gateway is fully retired – converting a permanent risk into a temporary, monitored one.
- **Downgrade-attack protection:** HTTP Strict Transport Security (HSTS) and TLS_FALLBACK_SCSV are enabled so that even modern-capable clients cannot be forced (e.g., by an attacker) down to SSL.
- **Cost optimisation:** Use open-source TLS termination (OpenSSL/NGINX) and free/low-cost certificate issuance (ACME/Let's Encrypt or existing bank CA) instead of proprietary hardware security appliances, and reuse existing load-balancer hardware where possible – satisfying constraint D last, after B, A and C are structurally guaranteed.
- **Monitoring:** SIEM/IDS rules flag any attempted SSL handshake against a sensitive endpoint, giving continuous assurance that constraint B is being enforced in production.

4. Application of Concepts

The design applies: TLS/SSL handshake and cipher-suite negotiation; protocol downgrade attack mitigation (HSTS, TLS_FALLBACK_SCSV); PKI and certificate management; reverse-proxy/TLS-termination architecture; network segmentation as a defence-in-depth control; blue-green / phased deployment strategy from secure systems engineering; and PCI-DSS style compliance mapping (data classification → protocol requirement).

5. Justification

Terminating TLS centrally and segmenting sensitive traffic guarantees constraint B absolutely, since the sensitive endpoints are architecturally incapable of accepting SSL – this is stronger than a policy-only control. Isolating the legacy protocol to non-sensitive endpoints resolves the apparent conflict between A and B: compatibility and "no-SSL-for sensitive-data" are no longer mutually exclusive. The blue-green rollout converts a risky one-time cut-over into a controlled, reversible process, protecting constraint C, while the reliance on open standards keeps constraint D achievable without new capital equipment.

The time-boxed legacy grace period ensures the compromise is temporary, moving the institution toward a fully TLS-only posture.

2. An e-commerce platform is considering implementing the SET protocol for payment security but currently uses TLS-based encryption. Analyze and propose a decision.

Constraints:

- A. Must support high transaction throughput (10,000 transactions/minute)
- B. Compatibility with modern browsers is required
- C. Implementation complexity should be minimized
- D. Regulatory compliance (PCI-DSS) must be ensured

Scenario: An e-commerce platform is considering implementing the SET protocol for payment security but currently uses TLS-based encryption. Analyze and propose a decision.

Constraints: (A) Must support high transaction throughput (10,000 transactions/minute) (B) Compatibility with modern browsers is required (C) Implementation complexity should be minimised (D) Regulatory compliance (PCI-DSS) must be ensured.

1. Problem Understanding

SET (Secure Electronic Transaction) was designed jointly by Visa and MasterCard to secure card-not-present e-commerce payments using dual-signature cryptography, so that the merchant sees only the order details and the bank sees only the payment details, with every party – cardholder, merchant, payment gateway, issuer – holding a digital certificate. TLS, by contrast, only secures the communication channel (confidentiality/integrity of the pipe) and is already deployed on the platform. The decision problem is whether the platform should adopt SET's heavier, multi-party PKI model on top of/instead of its existing lightweight TLS-based encryption, given hard operational and regulatory constraints.

2. Constraint Analysis & Prioritisation

Constraint	Description	Priority & Rationale
B	Must work with modern browsers.	Hard blocker for SET. SET required a proprietary "digital wallet" client plug-in; no modern browser ships native SET support, and the protocol is effectively obsolete/discontinued industry-wide.

D	PCI-DSS regulatory compliance is mandatory.	Hard requirement. Current PCI-DSS standards are written around TLS 1.2+ and tokenisation, not SET; compliance auditors assess against TLS/tokenisation controls.
A	10,000 transactions/minute throughput.	High. SET's per-transaction triple-certificate verification (cardholder, merchant, gateway) adds heavy cryptographic and PKI-lookup overhead per transaction, working against this target.
C	Implementation complexity minimised.	High. SET needs a full PKI roll-out to every cardholder plus wallet software distribution – far more complex than extending an already deployed TLS stack.

Because constraints B and D are structural blockers for SET (not merely trade-offs), and A and C are also worked against by SET's design, the constraint analysis points to a single feasible direction: **strengthen the existing TLS-based approach rather than adopt SET.**

3. Solution Development (Decision & Design)

Decision: Do not implement SET. Retain and harden the TLS-based payment architecture, supplemented with mechanisms that deliver SET's original security goals (strong cardholder authentication, transaction non-repudiation) in a browser-compatible, low-overhead way:

- **Upgrade to TLS 1.3** platform-wide to reduce handshake round-trips (1-RTT/0-RTT resumption), directly supporting the 10,000 tx/min throughput target (constraint A) while remaining fully browser-native (constraint B).
- **EMV 3-D Secure 2.0 (3DS2)** is adopted as the cardholder-authentication layer – it achieves the same 'proof the cardholder authorised this purchase' goal that SET's dual signature aimed for, but works through the existing browser/mobile SDK flow with no special client software.
- **Payment tokenisation** at the gateway (replacing raw PAN data with tokens) shrinks the PCI-DSS audit scope of the platform's own servers, directly supporting constraint D.
- **PCI-DSS certified payment gateway/processor** (Level 1 provider) handles card data end-to-end so the merchant application only ever touches tokens – minimising implementation complexity (constraint C) compared with building/operating a private PKI for SET.

- **Horizontal scaling** of TLS-terminating load balancers and payment microservices, with session resumption and hardware/AES-NI acceleration, to comfortably clear the 10,000 transactions/minute target.
- **Continuous PCI-DSS compliance program:** quarterly ASV scans, annual penetration testing and SAQ/ROC reporting appropriate to transaction volume, keeping constraint D satisfied on an ongoing basis.

4. Application of Concepts

The analysis applies: SET protocol internals (dual signature, cardholder/merchant/gateway certificate hierarchy) versus TLS handshake mechanics; PKI overhead comparison; EMV 3-D Secure as a modern successor to SET's authentication goal; PAN tokenisation; PCI-DSS scope-reduction principles; and throughput/latency engineering (TLS session resumption, load balancing) for highvolume transaction systems.

5. Justification

SET is rejected primarily because constraint B (modern-browser compatibility) cannot be met at all – SET requires client-side wallet software that current browsers do not support, making it a non-starter regardless of its theoretical security merits. Even if compatibility were possible, SET's multi-certificate verification per transaction works against both the throughput target (A) and the complexity target (C). The recommended TLS 1.3 + 3-D Secure 2.0 + tokenisation stack reproduces SET's core security intentions (strong authentication, reduced exposure of raw card data, non-repudiation) through mechanisms that are industry-standard, natively browser-supported and explicitly recognised by PCI-DSS – satisfying all four constraints (A, B, C, D) simultaneously, which SET cannot do.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Problem Understanding	25%	Clearly defines the problem and identifies all relevant constraints accurately	Identifies most constraints with minor gaps	Partial understanding; misses key constraints	Fails to identify constraints correctly
Constraint Analysis	25%	Analyzes constraints effectively and prioritizes them logically	Provides reasonable analysis with some prioritization	Limited analysis; weak prioritization	No meaningful analysis or prioritization
Solution Development	25%	Develops optimal and feasible	Develops workable solutions	Solutions partially	Solutions do not meet constraints
		solutions satisfying all constraints	with minor limitations	satisfy constraints	

Application of Concepts	15%	Effectively applies appropriate concepts, methods, or tools	Applies concepts with minor errors	Limited application; requires guidance	Unable to apply relevant concepts
Justification	10%	Provides strong justification for decisions with logical reasoning	Provides justification with some clarity	Weak or unclear justification	No justification provided